



Seu código **protegido** antes do deploy

Auditoria de segurança para repositórios do GitHub, explicada em português simples.

O QUE É

Um site que lê o seu repositório do GitHub e explica, em português simples, o que está perigoso antes do deploy.

Nunca executa o código

Primeira versão: Node.js e Express

Feito para quem programa com IA

PARA QUEM É

Quem vai usar o SpyCode

PERSONA PRINCIPAL

Rafael Nunes, 22 anos

Estudante de desenvolvimento no Senac

- Programa com Node.js, Express, React e MySQL
- Quer um GitHub bem cuidado para as entrevistas
- Sabe pouco de segurança: nota 1 de 5
- Acha as ferramentas em inglês e cheias de siglas
- Não pode pagar um plano profissional

PERSONA SECUNDÁRIA

Camila Souza, 27 anos

Dev júnior em uma startup

- Equipe de 4 devs, sem especialista em segurança
- Precisa de uma checagem rápida antes do deploy
- A empresa não tem verba para ferramenta corporativa
- Quer respostas diretas, sem alarme falso toda hora

Um dia comum do Rafael

O que o Rafael faz	O que o SpyCode mostra
1. Sobe o projeto com o arquivo .env junto	Segredos: a chave de pagamento está exposta
2. Apaga no commit seguinte e acha que resolveu	Histórico: a chave continua nos commits antigos
3. Cria uma rota de administração e esquece de proteger	Mapa de rotas: rota aberta, sem login
4. Instala uma biblioteca antiga, de um tutorial de 2019	Dependências: falha conhecida e a versão que corrige

Depois ele deixa o repositório público e coloca o link no currículo.

Como funciona

01

Entra com o GitHub

Só com permissão de leitura.

02

Escolhe o repositório

Público ou privado.

03

O SpyCode analisa

Lê o código sem executar e apaga a cópia no final.

04

Recebe o dossiê

Nota de 0 a 100 e cada achado com explicação e correção.

✓ Nunca executa o seu código

✓ Nunca guarda o seu código

✓ Segredo sempre mascarado

✓ Só com autorização do dono

O QUE ELE ENCONTRA

Três motores de análise



Caçador de segredos

Encontra chaves, tokens e senhas no código e em todo o histórico de commits.



Mapa de rotas

Lista as rotas da API e marca as abertas sem login. Também confere configurações perigosas.



Dependências

Cruza as bibliotecas com a base pública de falhas e mostra a versão que corrige.

Cada achado sai com a gravidade (**crítica**, **alta**, **média** ou **baixa**), o risco explicado e o passo a passo da correção.

Por dentro do SpyCode



O código fica só numa pasta temporária: os motores leem, nada é executado e a cópia é apagada no final.

Caixas tracejadas são serviços de fora do SpyCode.

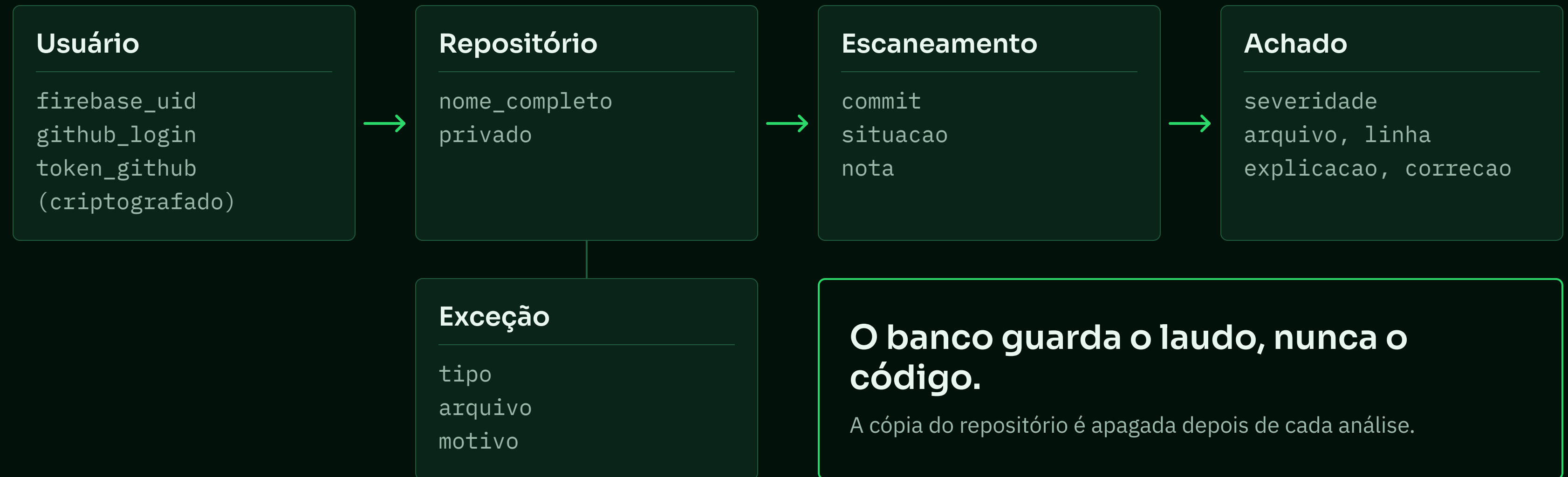
Do que o SpyCode é feito

Tudo em JavaScript

Uma linguagem só, do site ao servidor. Os projetos que o SpyCode analisa também são em JavaScript, então o grupo entende o que está lendo.

Parte	Tecnologia	Situação
Site	HTML, CSS e JavaScript	Pronto
Login	Firebase	Pronto
Servidor	Node.js e Express	Planejado
Banco de dados	PostgreSQL e Prisma	Planejado
Fila	BullMQ e Redis	Planejado
Leitura do código	@babel/parser	Planejado
Base de falhas	OSV.dev	Planejado
Hospedagem	Render ou Railway	Planejado

O que fica guardado



Cada usuário tem vários repositórios, que têm vários escaneamentos, que têm vários achados.

CONCORRENTES

O que já existe no mercado

Ferramenta	Segredos	Histórico	Dependências	Mapa de rotas	Painel
GitHub (nativo)	Sim	Sim	Sim	Não	Sim
GitGuardian	Sim	Sim	Sim	Não	Sim
Gitleaks / TruffleHog	Sim	Sim	Não	Não	Não
Snyk	Parcial	Não	Sim	Não	Sim
Aikido Security	Sim	Sim	Sim	Parcial	Sim
SpyCode (planejado)	Sim	Sim	Sim	Sim	Sim

As ferramentas do mercado são mais completas e atendem mais linguagens. O SpyCode junta essas análises para quem está começando.

Onde o SpyCode é diferente

EXEMPLO DE ACHADO

Gravidade alta

Rota DELETE /users/:id sem autenticação

O RISCO

Qualquer pessoa na internet pode apagar usuários.

COMO CORRIGIR

Coloque o middleware de autenticação antes da função da rota.

Explica em português simples

Cada achado diz qual é o risco e como corrigir, passo a passo.

Mapa de rotas

Mostra quais rotas da API estão abertas sem login.

Tudo em uma análise

Segredos, histórico, rotas e dependências no mesmo dossiê.

Gratuito, feito para estudantes

Sem plano pago e sem limite de colaboradores.

HOJE E AMANHÃ

Onde estamos e para onde vamos

HOJE

Pronto

- Página inicial do site
- Tela de login com GitHub, Google e e-mail

PRIMEIRA VERSÃO

A construir

- Os três motores de análise
- Painel com o dossiê e a nota
- Testes em projetos de colegas, com autorização

DEPOIS

Visão de futuro

- Outras linguagens além de Node.js e Express
- Correção sugerida em pull request
- IA que explica o achado no contexto do código

A PESQUISA

Por que escolhemos este projeto

84%

dos desenvolvedores usam ou pretendem usar IA para programar

45%

dos testes terminaram com falha de segurança no código gerado por IA

28,65 mi

de segredos novos expostos no GitHub público em 2025, 34% a mais que em 2024

R\$ 7,19 mi

é o custo médio de uma violação de dados no Brasil

Mais código feito com IA, mais falhas indo para o ar. O SpyCode é a segunda leitura antes do deploy.